

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Learning Objectives

By the end of this lecture and its accompanying guide, you will be able to:

- By the end of this lecture you will be able to explain how edge computing distributes cloud infrastructure and the specific security challenges this creates around physical access, monitoring, and update cycles.
- By the end of this lecture you will be able to describe how confidential computing uses hardware-based trusted execution environments to protect data in use, and name the major implementations including Intel SGX and AMD SEV.
- By the end of this lecture you will be able to articulate why the proliferation of non-human identities in cloud environments creates an identity management challenge distinct from traditional user account governance.
- By the end of this lecture you will be able to identify the supply chain security dependencies introduced by each related technology, including ML training data, container images, blockchain oracles, and edge firmware.
- By the end of this lecture you will be able to describe the regulatory landscape surrounding related technologies, including the EU AI Act, IoT security legislation, and NIST post-quantum cryptography standards.
- By the end of this lecture you will be able to explain how zero trust architecture responds to the security challenges created by the convergence of IoT, containers, edge, and AI in cloud environments.

Introduction

The previous lecture established how machine learning, AI, blockchain, IoT, containers, and quantum computing each extend the cloud security problem. This lecture examines the second set of related technologies on the CCSP exam outline and, critically, the cross-cutting themes that connect all of them: non-human identity management, supply chain security, the evolving regulatory environment, and zero trust architecture as the strategic response to a perimeter that can no longer be meaningfully defined.

Edge computing and confidential computing represent two different responses to the limitations of traditional cloud architectures. Edge computing moves computation closer to where data is generated, reducing latency but distributing infrastructure into environments with less physical security and weaker operational discipline than a professional data centre. Confidential computing addresses the gap that even well-secured cloud environments leave open: the moment when data is decrypted for processing, a window during which even a trusted cloud provider technically has access to plaintext. Understanding both technologies as architectural choices with distinct security trade-offs is what the CCSP exam tests.

The regulatory dimension of these technologies is no longer a future concern. The EU AI Act is law. IoT security legislation has been enacted in the United Kingdom, the United States, and other jurisdictions. NIST has

published post-quantum cryptography standards. Cloud security professionals operating in regulated industries must track this evolving compliance landscape as attentively as they track technical vulnerabilities, because the obligations are real and the timelines for compliance are active.

Core Concepts Explained

Edge Computing Security

Definition: Edge computing moves computation and data processing physically closer to where data is generated, reducing the latency involved in routing data to a centralised cloud data centre. Edge nodes may be located in factories, retail stores, telecommunications facilities, hospitals, or other operational environments that lack the physical security controls of a professional data centre.

Business relevance: Organisations deploy edge computing to enable real-time analytics, reduce bandwidth costs, and support use cases where cloud latency is operationally unacceptable. However, each edge node is a distributed piece of cloud infrastructure in an environment with fewer physical access controls, less rigorous patch cycles, and often no dedicated security personnel on site. An attacker with physical access to an edge node may be able to extract credentials, tamper with software, or use the node as a pivot into the cloud environment it connects to.

Cloud Security Practitioner relevance: A Cloud Security Practitioner designing an edge computing deployment must explicitly extend cloud security controls to edge nodes, including device attestation, tamper detection, automated patch management, and monitoring that accounts for the reality that edge nodes may be physically accessible to untrusted parties.

Real-world example: A telecommunications provider deployed edge computing nodes at regional facilities to process video streaming data locally rather than routing it to a central data centre. During a security review, the practitioner found that several edge nodes were running operating system versions that were fourteen months behind on patches, had USB ports enabled with no policy controls, and reported health status to the cloud management plane but had no outbound traffic anomaly detection. An attacker with brief physical access to one node during a maintenance window could install a persistent backdoor and use the node outbound connection to the cloud control plane as a command-and-control channel. The remediation required automated patch enforcement through the cloud management agent, USB port disablement via firmware policy, and installation of an endpoint detection agent tuned for the edge node traffic profile.

Risks or limitations: Physical accessibility of edge nodes, infrequent update cycles, and limited on-site monitoring create a higher-risk infrastructure profile than a data centre. The best practices are immutable operating system images that can only be updated through signed rollout from the cloud management plane, hardware attestation at boot using Trusted Platform Module chips, and network segmentation that treats edge nodes as untrusted sources even for connections to the cloud management plane.

Confidential Computing and Trusted Execution Environments

Definition: Confidential computing protects data while it is being actively processed by using hardware-based trusted execution environments, also called secure enclaves, to ensure that data remains encrypted even while the CPU is operating on it. This addresses the gap left by standard encryption, which protects data at rest and in transit but leaves it exposed in plaintext during processing.

Business relevance: In multi-tenant cloud environments, even with strong logical isolation between tenants, the cloud provider's administrators technically have access to the physical hardware and could in principle access plaintext data during processing. Confidential computing provides a hardware-enforced guarantee,

backed by remote attestation, that even the cloud provider cannot access the contents of a secure enclave. This is particularly significant for regulated data, joint venture data processing between competing organisations, and any workload where the data owner cannot fully trust the infrastructure operator.

Cloud Security Practitioner relevance: A Cloud Security Practitioner evaluating confidential computing for a regulated workload must understand the attestation model, the boundary of what the enclave protects and what it does not, and the operational complexity that confidential computing introduces to development and deployment pipelines.

Real-world example: A multinational bank and a competitor agreed to collaborate on a fraud detection model that would benefit from each bank contributing transaction data, but neither was willing to share raw customer transaction records with the other. They implemented a confidential computing architecture on a major cloud provider using Intel Software Guard Extensions, where each bank's data was encrypted before loading into the enclave, processed inside the enclave to train a joint model, and the resulting model exported without either party's raw data ever being accessible to the other or to the cloud provider. Remote attestation, in which the enclave cryptographically proves to each party that it is running the agreed code in a genuine SGX environment, was the trust anchor for the arrangement. This architecture is now used in several regulated financial services and healthcare data collaboration contexts and represents a concrete application of confidential computing beyond theoretical discussion.

Risks or limitations: Side-channel attacks against trusted execution environments, including timing attacks and cache-based attacks, have been demonstrated in research. AMD Secure Encrypted Virtualisation and Intel SGX have both had vulnerabilities discovered that required microcode or firmware patches. Confidential computing is a strong control but not an absolute one, and its security depends on keeping the underlying hardware and firmware current.

Non-Human Identity Management at Scale

Definition: In modern cloud environments, the population of identities that access cloud resources includes not only human users but also IoT devices, container workloads, AI systems making API calls, microservices communicating with each other, and automated pipelines. These non-human identities often outnumber human users by orders of magnitude in a large cloud environment.

Business relevance: Non-human identities are frequently managed with less rigour than human accounts. Service accounts may accumulate excessive permissions over time without periodic review. Machine credentials are often long-lived, shared across services, or embedded in code where they are difficult to rotate. A compromised non-human identity in a cloud environment can represent as significant a breach as a compromised privileged human account, particularly if the identity has broad access to cloud APIs or data stores.

Cloud Security Practitioner relevance: A Cloud Security Practitioner must apply the same identity governance principles to non-human identities as to human accounts: least-privilege access, time-limited credentials, regular access reviews, and centralised identity management. In practice this means using cloud provider managed identities or workload identity federation rather than long-lived API keys wherever possible.

Real-world example: A large e-commerce platform operating in a major cloud environment conducted an identity audit and discovered that it had approximately 340 human user accounts and over 12,000 service accounts, many of which had not been accessed in over six months but retained broad permissions inherited from original provisioning. Several service accounts had AWS-equivalent AdministratorAccess policies attached because it was convenient during initial development and the permissions were never scoped down for production. The audit also found 47 API keys embedded in container environment variables that were more than two years old and had never been rotated. The remediation program required implementing managed

service identities for all container workloads, enforcing 90-day credential rotation for any remaining API keys, and establishing a quarterly automated access review that flagged any service account unused for 30 days for deprovisioning or re-justification.

Risks or limitations: Overprivileged, long-lived, and unreviewed non-human credentials are among the most commonly exploited attack vectors in cloud breaches. The best practices are managed identities and workload identity federation over static API keys, least-privilege scoping at provisioning time, automated credential rotation, and regular access reviews that explicitly include non-human identities.

Supply Chain Security for Related Technologies

Definition: Each of the related technologies introduces distinct supply chain dependencies: ML models depend on training data whose integrity may not be verifiable, container deployments depend on base images from upstream registries, blockchain smart contracts may depend on external data feeds called oracles, and edge computing nodes depend on firmware from manufacturers with varying security practices.

Business relevance: Supply chain attacks target these dependencies because compromising an upstream component automatically compromises every downstream system that depends on it. The SolarWinds compromise of 2020, in which a software update mechanism was used to distribute malicious code to thousands of organisations, is the most prominent example of the supply chain attack model at scale. Each related technology creates an analogous dependency that requires explicit security evaluation.

Cloud Security Practitioner relevance: A Cloud Security Practitioner must map the supply chain dependencies of each technology deployed in a cloud environment, assess the security practices of each upstream supplier, and implement controls that can detect or contain the impact of a compromised dependency.

Real-world example: A cybersecurity firm discovered in 2021 that a widely used npm package dependency embedded in multiple container images had been updated by a malicious actor who had gained control of the maintainer account. The malicious update installed a credential harvester that exfiltrated environment variables, including cloud provider access keys, from any container that loaded the package. Organisations with private image registries and signed images detected the issue when the image signature of their base image changed unexpectedly after the malicious update was pulled. Organisations pulling directly from public registries without signature verification or vulnerability scanning had no automated detection and were only alerted when the malicious package was publicly disclosed. The lesson is that supply chain integrity controls, specifically image signing and dependency scanning, are the difference between early automated detection and delayed disclosure-dependent detection.

Risks or limitations: Supply chain dependencies for related technologies are often assumed to be trusted by virtue of being commonly used. Signature verification of all external dependencies, software bill of materials documentation for all deployed components, and monitoring of upstream sources for integrity changes are the best practices that provide supply chain visibility.

Zero Trust Architecture as a Response to Technology Convergence

Definition: Zero trust architecture operates on the principle that no user, device, or service should be trusted by default, regardless of whether it is inside or outside the traditional network perimeter. Every access request must be verified against identity, device health, and authorisation policy before access is granted, and access is continuously re-evaluated rather than assumed to persist once established.

Business relevance: The convergence of IoT, edge computing, containerised microservices, and AI systems makes the traditional network perimeter increasingly difficult to define and defend. An IoT device connecting from a factory floor, a container running in a managed cloud service, and an AI system making API calls from an

edge node are all accessing cloud resources from points outside any meaningful perimeter. Zero trust responds to this reality by making the identity and policy layer the security boundary rather than the network.

Cloud Security Practitioner relevance: A Cloud Security Practitioner implementing zero trust in a cloud environment must establish a centralised identity provider that covers both human and non-human identities, implement policy enforcement points at every API and service boundary, ensure continuous health monitoring of accessing devices, and design network architecture that enforces least-privilege connectivity rather than relying on implicit trust within a network segment.

Real-world example: A global logistics company replaced its traditional VPN-based remote access architecture with a zero trust network access implementation after finding that the VPN model gave excessive implicit trust to any device that authenticated. The new architecture required every access request, whether from a human employee, an IoT fleet tracking device, or an automated logistics optimisation service, to present a valid identity credential and pass a device health check before being granted access to specific cloud resources. The policy enforcement was handled by the cloud provider identity-aware proxy. The result was that when a fleet tracking IoT device was reported stolen in South America, the security team was able to immediately revoke its device certificate and confirm within minutes that the device had made no further authorised API calls, whereas under the previous VPN model a stolen device with cached credentials would have continued to be trusted until the VPN session expired.

Risks or limitations: Zero trust implementation requires a mature identity infrastructure, including a reliable source of truth for device health and a centralised policy engine. Partial zero trust implementations that cover human users but leave non-human identities under less rigorous controls create false confidence. The best practice is to implement zero trust principles consistently across all identity types from the initial design rather than retrofitting them later.

Practical Applications

The following scenarios illustrate how cloud security professionals apply these concepts when advising on architecture, compliance, and operational security decisions.

Extending Security Controls to Edge Computing Infrastructure

A retail company operates 500 edge computing nodes at store locations to run local inventory analytics and point-of-sale fraud detection. A cloud security practitioner is asked to assess the security posture of this infrastructure. The assessment finds that nodes are deployed with a standard operating system image that has not been updated since initial deployment eighteen months ago, no hardware attestation is in place, and the nodes communicate to the cloud management plane using a shared service account credential stored in a configuration file on each device. The practitioner designs a remediation program with three components: first, migration to an immutable OS image model where software updates are delivered as signed, versioned image replacements pushed from the cloud management plane rather than applied through local package managers; second, implementation of TPM-based hardware attestation so the cloud management plane can verify the integrity of each node at boot; and third, replacement of the shared service account credential with individual device certificates issued by a cloud-managed certificate authority and rotated every 30 days. The practitioner also recommends configuring the cloud firewall to allow each node to communicate only with its designated management endpoint and analytics data sink, preventing any outbound connectivity to unexpected destinations.

Evaluating Regulatory Compliance Requirements for an AI-Powered Decision System

A financial services firm is deploying an AI system in a cloud environment to assist in credit underwriting decisions. The cloud security practitioner is asked to assess regulatory obligations. The assessment begins by classifying the AI system under the EU AI Act, which categorises credit scoring and creditworthiness assessment as high-risk AI use cases requiring specific technical and governance obligations including transparency to affected individuals, human oversight mechanisms, accuracy and robustness testing, and documentation of training data. The practitioner maps these requirements to technical controls: logging of every AI-assisted decision with the inputs, outputs, and model version used; a human review workflow for any case where the AI recommendation deviates significantly from historical patterns; regular model validation testing against defined performance metrics; and a model card documenting training data sources, data governance measures applied, and known limitations. The assessment also notes that the firm processes EU resident data, making the AI Act applicable regardless of where the cloud infrastructure is hosted.

Implementing Non-Human Identity Governance Across a Cloud Environment

A software company operating a multi-cloud environment asks its security team to improve its management of service accounts and machine credentials after an incident in which a long-lived API key embedded in a CI/CD pipeline was used to exfiltrate source code. The cloud security practitioner designs an identity governance program with four elements. First, a discovery phase using cloud provider identity analysis tools to enumerate all service accounts, API keys, and machine credentials in use, their age, their permission scope, and their last use date. Second, a remediation phase that replaces static API keys with managed service identities or workload identity federation tokens wherever the cloud provider and application support it, targeting the highest-risk credentials first based on permission scope. Third, a rotation policy requiring that any remaining static credentials be rotated every 90 days with automated enforcement through the CI/CD pipeline. Fourth, a quarterly access review process that explicitly covers non-human identities and requires documented justification for any service account that holds permissions beyond the minimum needed for its documented function.

Best Practices

- **Treat edge computing nodes as untrusted infrastructure even when they are owned and operated by your organisation.** Implement hardware attestation using TPM chips to verify node integrity at boot, deploy immutable OS images updated through signed rollout from the cloud management plane rather than local package managers, and configure network policy so edge nodes can communicate only with designated cloud endpoints. Do not use shared credentials across edge nodes; provision each node with a unique device certificate.
- **Apply the same identity lifecycle governance to non-human identities as to privileged human accounts.** Use managed service identities or workload identity federation tokens in preference to static API keys wherever the platform supports it. Enforce 90-day rotation for any remaining static credentials. Run quarterly automated access reviews that flag service accounts unused for 30 days and require documented justification for any non-human identity holding permissions beyond its minimum operational requirement.
- **Verify supply chain integrity for all external dependencies including container images, ML training data, and edge firmware.** Require image signing for all container images and verify signatures at admission. Maintain a software bill of materials for all deployed components. Establish monitoring that alerts when the signature or hash of a trusted upstream component changes unexpectedly. Treat any unsigned or unverifiable dependency as an untrusted supply chain input.

- **Design zero trust architecture to cover non-human identities from the outset, not as a retrofit.** Ensure the identity provider covers IoT devices, container workloads, and AI service identities with the same policy enforcement applied to human users. Implement policy enforcement points at every API and service boundary, and configure continuous device health checks so that a compromised device credential can be revoked and its access terminated immediately rather than persisting until session expiry.
- **Track the regulatory obligations of related technologies as actively as technical vulnerability disclosures.** Assign ownership of EU AI Act compliance monitoring, IoT security legislation tracking, and NIST post-quantum standards adoption to named individuals or teams. Incorporate regulatory change triggers into your change management process so that a new regulation, standard, or enforcement action automatically generates a compliance gap assessment for affected cloud workloads. Do not assume that regulatory requirements stabilise; in this space they are actively evolving.

Common Mistakes and Misconceptions

Misconception: Assuming edge computing nodes inherit the security posture of the cloud environment they connect to because they are managed through a cloud console.

Correct approach: Edge nodes are physically accessible infrastructure in environments with fewer security controls than a data centre. Apply hardware attestation, immutable OS images, unique device credentials, and network policy enforcement that treats edge nodes as untrusted sources, even for connections to the cloud management plane.

Misconception: Treating confidential computing as a complete security solution that eliminates all trust concerns in a multi-tenant cloud environment.

Correct approach: Confidential computing with hardware-based trusted execution environments and remote attestation is a strong control, but it is not absolute. Side-channel attacks have been demonstrated against both Intel SGX and AMD SEV. Maintain hardware and firmware currency for enclave-based workloads and understand the specific threat model that confidential computing addresses versus what remains outside its protection boundary.

Misconception: Managing non-human service accounts and machine credentials with less rigour than human accounts on the assumption that machines are less likely to be compromised.

Correct approach: Non-human credentials are among the most commonly exploited attack vectors in cloud environments because they are often long-lived, overprivileged, and shared. Apply least-privilege scoping, 90-day rotation, and quarterly access reviews to all non-human identities. Use managed service identities over static API keys wherever possible.

Misconception: Implementing zero trust for human users while leaving IoT devices, containers, and AI service identities under legacy implicit trust models.

Correct approach: Zero trust must cover all identity types to be effective. An IoT device or container workload with implicit network trust can be as significant an attack vector as a compromised human user account. Design zero trust policy enforcement to cover non-human identities from the initial implementation, not as a future phase.

table: Related Technology Regulatory Compliance Reference

The following table maps each related technology to its primary regulatory frameworks and compliance obligations relevant to cloud environments as of 2026. Use this as a starting point for compliance gap assessment rather than an exhaustive legal reference.

Technology	Key Regulation or Standard	Jurisdiction	Primary Cloud Security Obligation
AI and ML	EU AI Act	European Union	High-risk AI systems require transparency, human oversight, accuracy testing, and training data documentation
AI and ML	NIST AI RMF (AI 100-1)	United States	Risk management framework for AI systems including cloud-hosted models
IoT	Product Security and Telecommunications Infrastructure Act	United Kingdom	Minimum security requirements for connected devices including no default passwords
IoT	IoT Cybersecurity Improvement Act	United States	Security standards for IoT devices procured by federal agencies
Post-Quantum Cryptography	NIST FIPS 203, 204, 205	Global reference	Approved post-quantum algorithms for key encapsulation and digital signatures
Confidential Computing	FIPS 140-2/3	Global reference	Cryptographic module validation standard for hardware security modules and TEEs
General Cloud AI Data	GDPR Article 22	European Union	Right not to be subject to solely automated decisions with significant effects

How to use this: Regulatory requirements evolve; verify current obligations with legal counsel. The EU AI Act entered into force in 2024 with phased compliance deadlines; high-risk AI provisions apply from August 2026.

Knowledge Check

Test your understanding before moving on. Answers are shown below each question.

Q1. A cloud security practitioner is reviewing an edge computing deployment where 200 nodes at retail locations manage point-of-sale fraud detection. The nodes have not received OS updates in 18 months, use a shared service account credential, and have USB ports enabled. Which remediation priority order best addresses the highest risks first?

- A) A. Disable USB ports, then migrate to unique device certificates, then implement automated OS updates
- B) B. Implement automated OS updates first, then disable USB ports, then migrate to unique device certificates
- C) C. Migrate to unique device certificates and implement immutable OS images with signed rollout, then disable USB ports, then configure network policy to restrict node egress
- D) D. Recentralise all computation to the cloud data centre to eliminate edge security risks

Answer: C. Migrate to unique device certificates and implement immutable OS images with signed rollout, then disable USB ports, then configure network policy to restrict node egress

Q2. A multinational bank wants to collaborate with a competitor on a joint fraud detection model without sharing raw customer transaction records with each other or with the cloud provider. Which technology provides the strongest technical guarantee that neither party nor the cloud provider can access the other's plaintext data during model training?

- A) A. Client-side encryption with customer-managed keys stored in each bank's on-premises HSM
- B) B. Network encryption using TLS 1.3 between the two banks cloud environments
- C) C. Confidential computing using hardware-based trusted execution environments with remote attestation
- D) D. Tokenisation of all transaction records before sharing them with the joint training environment

Answer: C. Confidential computing using hardware-based trusted execution environments with remote attestation

Q3. A security audit of a cloud environment reveals 340 human user accounts and 12,000 service accounts. Many service accounts have not been used in six months, hold broad permissions inherited from initial development, and use API keys over two years old. Which principle does this situation most critically violate, and what is the first remediation action?

- A) A. Defence in depth; implement multi-factor authentication for all service accounts immediately
- B) B. Least privilege and identity lifecycle governance; conduct an automated discovery and access review to identify and deprovision unused service accounts and scope down overprivileged active ones
- C) C. Separation of duties; ensure no service account can perform both read and write operations on the same resource
- D) D. Zero trust; require all service accounts to re-authenticate every 24 hours

Answer: B. Least privilege and identity lifecycle governance; conduct an automated discovery and access review to identify and deprovision unused service accounts and scope down overprivileged active ones

Q4. A container image used by multiple organisations is found to have been modified in a public registry by a malicious actor who gained control of the maintainer account. Organisations that detected the incident through automated alerting shared one control in common. What was it?

- A) A. They had configured container resource limits that prevented the malicious code from consuming excessive CPU
- B) B. They were using a private image registry with image signing and received automated alerts when the signature of the base image changed unexpectedly
- C) C. They had network policies that blocked outbound traffic from containers to external IP addresses
- D) D. They had enabled cloud provider managed encryption for all container volumes

Answer: B. They were using a private image registry with image signing and received automated alerts when the signature of the base image changed unexpectedly

Q5. A logistics company implements zero trust network access for its 5,000 human employees but leaves its 15,000 IoT fleet tracking devices and 200 automated logistics services under a legacy implicit trust model. What is the primary security gap this creates?

- A) A. Human employees will have slower access to cloud resources than IoT devices due to the additional verification overhead
- B) B. IoT devices and automated services, which outnumber human users three-to-one, remain implicitly trusted and can be exploited without triggering zero trust controls

- C) C. The cloud provider will charge higher rates for environments that mix zero trust and legacy access models
- D) D. Zero trust cannot be extended to non-human identities and the organisation should accept this limitation

Answer: B. IoT devices and automated services, which outnumber human users three-to-one, remain implicitly trusted and can be exploited without triggering zero trust controls

Reflection Questions

1. Edge computing nodes are described as distributed infrastructure with weaker physical security than a data centre. In your organisation or a relevant context you are familiar with, what mechanisms currently exist to verify the integrity of remotely deployed infrastructure, and where are the gaps?
2. Confidential computing using TEEs provides a technical guarantee against cloud provider access to plaintext data during processing. Under what regulatory or contractual circumstances would this level of assurance be operationally necessary rather than theoretically desirable?
3. The example of 340 human accounts and 12,000 service accounts illustrates how non-human identity populations can dwarf human user populations. If you were to conduct a non-human identity audit of a cloud environment you are familiar with, what would your discovery methodology look like?
4. The EU AI Act establishes risk-based requirements for AI systems used in consequential contexts. Consider an AI system used for a consequential decision in your industry. What documentation, oversight mechanisms, and testing requirements would apply under a high-risk classification?
5. Zero trust is described as the cloud natural home because it provides centralised identity, policy, and enforcement infrastructure. What aspects of your current environment most significantly depend on implicit network trust, and what would it take to replace them with explicit policy enforcement?

Key Takeaways

- Edge computing distributes cloud infrastructure into environments with less physical security, weaker update cycles, and limited monitoring; securing edge nodes requires hardware attestation, immutable OS images, unique device credentials, and network policy enforcement.
- Confidential computing uses hardware-based trusted execution environments to protect data in use, providing a hardware-enforced guarantee that even a cloud provider cannot access plaintext during processing; Intel SGX and AMD SEV are the major implementations.
- Non-human identities including IoT devices, containers, and AI services typically outnumber human users in modern cloud environments and require the same lifecycle governance: least privilege, credential rotation, and regular access reviews.
- Each related technology introduces distinct supply chain dependencies; signature verification, software bill of materials, and upstream integrity monitoring are the controls that provide supply chain visibility.
- The EU AI Act, IoT security legislation in multiple jurisdictions, and NIST post-quantum cryptography standards represent active regulatory obligations that cloud security professionals must track alongside technical vulnerability disclosures.
- Zero trust architecture is the strategic response to the convergence of IoT, containers, edge, and AI because it replaces perimeter-based implicit trust with identity-verified, policy-enforced access for every request regardless of origin.

- Partial zero trust implementations that cover human users but leave non-human identities under legacy implicit trust models create significant gaps because non-human identities often outnumber and outpace human accounts in scale and attack surface.

Recommended Next Actions

Put this lecture to work within the next seven days:

6. Identify any edge computing nodes in your environment and verify whether each has a unique device credential, automated patch management, and hardware attestation; document gaps as remediation items.
7. Conduct a non-human identity discovery exercise in one cloud account or project using your cloud provider identity analysis tools; document how many service accounts exist, when they were last used, and what permissions they hold.
8. Review your organisation current regulatory obligation mapping for AI systems in cloud environments and confirm whether any deployed AI systems would qualify as high-risk under the EU AI Act, triggering specific documentation and oversight requirements.
9. Evaluate whether your current zero trust implementation, if any, explicitly covers IoT devices and container workload identities or only human user access, and identify the steps required to extend policy enforcement to non-human identity types.